

NIP first ARB review — presenter script

FIRST REVIEW — DEV/UAT environment shape. Not production go-live, not DR-ready sign-off, not T4, not Board 4, not CIS register, not VA/PT.

Opening (memorise)

Thank you. This is the first Architecture Review Board sitting for the Insurance Distribution Platform — NIP.

We are not here for production go-live, and we are not here for DR-ready sign-off. Those will be later, fuller sittings.

Today we ask you to review the architecture we intend to build, confirm it is aligned with bank platform standards, and allow us to stand up Dev and UAT — Dev lives inside the UAT AWS account — so engineering can proceed.

I will walk one complete sale, then the cloud and network shape, then security, identity, data, audit, and DR as designed. I will be explicit about what is already bank-standard, what is different and why, and what we are still waiting on from other teams.

If a question needs a measured answer we do not have in the room — for example an Apigee IP list — I will record it as an action rather than guess. That kind of item should not block the Dev/UAT environment shape.

Sixty minutes. Comments welcome. We will park anything that belongs to the production ARB.

Five plays when you do not know

Play 1 — Cite and stop

That decision is recorded in ADR-0XX. I will not re-litigate it from memory. Happy to walk the clause after the sitting if needed.

Play 2 — Name the owner

The structure is Architecture's. The remaining acceptance sits with [Deepali / Shivanshi / bank network / Apigee team]. I will not speak for their residual.

Play 3 — Action, dated, non-blocking

Fair question. I do not have a measured answer in the room and I will not invent one. Action: we return by [date] with [owner]. That item does not change the Dev/UAT VPC shape we are asking you to review today.

Play 4 — Wrong sitting

That is a production / DR-readiness / VA-PT question. We will bring it to the second ARB with evidence. Today is the first review of the intended design so we can stand up Dev and UAT.

Play 5 — Never guess

I will not guess an IP, a pentest result, a restore-drill time, or a CIS register class. Guessing those in this room would be the actual control failure.

Slide 1. First ARB review — Dev & UAT (3 min)

SAY: Thank you. This is the first Architecture Review Board sitting for the Insurance Distribution Platform — NIP.

We are not here for production go-live, and we are not here for DR-ready sign-off. Those will be later, fuller sittings.

Today we ask you to review the architecture we intend to build, confirm it is aligned with bank platform standards, and allow us to stand up Dev and UAT — Dev lives inside the UAT AWS account — so engineering can proceed.

I will walk one complete sale, then the cloud and network shape, then security, identity, data, audit, and DR as designed. I will be explicit about what is already bank-standard, what is different and why, and what we are still waiting on from other teams.

If a question needs a measured answer we do not have in the room — for example an Apigee IP list — I will record it as an action rather than guess. That kind of item should not block the Dev/UAT environment shape.

Sixty minutes. Comments welcome. We will park anything that belongs to the production ARB.

IF ASKED: If someone asks 'is this production approval?' — No. Say it twice. Write it on the parking lot.

DO NOT: Do not say 'AI designed this'. Do not say 'we need production'. Do not apologise for the architecture.

Slide 2. Why we are here — and what we are not asking (3 min)

SAY: Please look at the two columns in your mind: today versus later. Today is design review plus Dev/UAT. Later is production and DR. If a comment is really a production control, I will park it for the second sitting so we do not spend the hour there.

IF ASKED: If they say 'we only ARB once' — we still cannot evidence DR or VA/PT today. We are asking for a staged review, which matches how landing zones are vended.

DO NOT: Do not accept 'approve everything now'. Do not accept 'come back when prod-ready' if that blocks Dev/UAT — that is the chicken-and-egg.

Slide 3. 60 minutes — how we will use them (1 min)

SAY: I will keep moving. Please park deep dives. Appendix slides at the back are glossary and FAQ — we open them only if needed.

IF ASKED: If they want to jump to network first — agree. Skip to the front-door slide. The sale trace can wait 2 minutes.

DO NOT: Do not read this table aloud line by line.

Slide 4. Business — what NIP is (row 1 of the pack) (4 min)

SAY: This is an insurance distribution platform owned by the bank, not a 1SilverBullet skin. 1SB is a provider route we can replace. The RM never pays on the RM device. The customer pays on the customer's device. If we get that wrong, we do not have an IRDAI-safe journey.

IF ASKED: Health / Motor / DIY are later horizons. Do not design them in this hour. H1–H3 are direction, not this submission.

DO NOT: Do not invent a business BRD signature. Rajal owns Product sign-off.

Slide 5. One sale, end to end — follow Priya (5 min)

SAY: Forget boxes for one minute. This trace IS the architecture. Flutter never calls 1SB, never calls RDS, never calls Apigee. Customer phone appears twice: OTP and pay. If someone proposes a shortcut that skips suitability, consent, customer-device pay, or audit-before-sold — that is not a simplification, that is a control failure.

IF ASKED: Why so many services? Because Health later must not rewrite Life. Quote and suitability are different systems of record. We will not merge them to look smaller on a slide.

DO NOT: Do not demo a god-service. Do not say Kafka is the audit log.

Slide 6. Front door — inbound (ADR-018) | why not a public ALB (6 min)

SAY: This will attract the most questions. The one-line answer: a public ALB in front of API Gateway is an extra attack surface and an extra hop the insurance platform does not need. Cloudflare and F5 are already the bank perimeter, and they are SaaS — they do not sit in our VPC. Internal ALB is the only load balancer inside the VPC. If the room wants the neighbour app's Public ALB copied, that is a change to ADR-018, not a tweak. It would also require Deepali, not just Architecture.

IF ASKED: Use FAQ 1–3. If they insist, Play 2: Deepali owns the exposure outcome. Play 3: we will not redesign the front door in the last twenty minutes.

DO NOT: Do not agree to 'just a public ALB for Dev'. Dev that is public is a prod-shaped hole with synthetic data until someone puts a real CIF in it.

Slide 7. Where it runs — attach, do not clone (4 min)

SAY: This is the R0 topology. Please notice three things. One: we attach as a spoke to the existing AU-CTO-NETWORK Transit Gateway — we do not build a second hub, a second Direct Connect, or a FortiGate pair in our VPC. Two: inbound is Cloudflare / F5 / API Gateway. Three: outbound leaves via Apigee. The picture is a rendering of the LLD. If it disagrees with an ADR, the ADR wins.

IF ASKED: If they cannot read the picture, go to the next two slides which are the same facts in words.

DO NOT: Do not apologise that it is busy. Offer the LLD after the meeting.

Slide 8. Loading dock — outbound (ADR-020) | why not NAT EIPs to 1SB (5 min)

SAY: Two different outsides. Mixing them is how CIF ends up on the public internet. Bank systems stay private. Internet partners go through Apigee. If someone says 'just whitelist our NAT IPs like last year' — that allowlists the wrong host. 1SB will see Apigee, not our NAT.

IF ASKED: Apigee edition and exact IPs are still with the Apigee team (DEP-20260914-apg). Play 3. Dev can use stubs; UAT needs the private path or a dated exception — Shivanshi.

DO NOT: Do not read out an IP. Do not promise the Apigee product exists today.

Slide 9. Five accounts — Dev inside UAT — no CUG (3 min)

SAY: Bank onboarding default is Prod, CUG, UAT, with Dev inside UAT. We are not asking for a separate Dev account. We are not asking for CUG at R0 — waiver, do not provision. Isolation is two VPCs, namespaces, schemas, Valkey prefixes, Apigee products. That is how we keep cost down without mixing stub CBS and real CBS.

IF ASKED: If Cloud wants a split Dev account — that is a cost exception they own. We can consume it; we are not requesting it. CUG has no R0 consumer.

DO NOT: Do not offer to vendor prod in the same request 'while we are here'.

Slide 10. Security architecture — seven trust boundaries (4 min)

SAY: If Security asks 'where is the VA/PT report?' the honest answer is: there is none, and we will not claim there is. Dev/UAT can be stood up with SAST in CI. Production ARB will not. Please do not hold Dev/UAT for a pentest of an environment that does not exist yet.

IF ASKED: Play 4 on pentest. Play 2 on ADR-010 firewall remainder.

DO NOT: Do not say 'we will pentest next week' unless Swapnali/Deepali have a date.

Slide 11. Identity — IAM and PAM (3 min)

SAY: The sentence that must survive this slide: we are not binding LDAP from Kubernetes to Active Directory. That would be a new attack path the bank does not need. AD-verify is an API the bank already has.

IF ASKED: Password-in-NIP vs Fireframe SSO is a joint item with Deepali (ID-11). Play 2. It does not change VPC vending.

DO NOT: Do not offer to 'just LDAP for Dev'.

Slide 12. Data, residency, audit vs logs (3 min)

SAY: Please do not let anyone treat Kibana as the audit pack. Search can be rebuilt. WORM cannot be shortened because we are in a hurry to decommission.

IF ASKED: CIS class is proposed Critical; Shailja + CISO register it. Architecture does not. Play 2. Dev/UAT still uses the same control set — we do not build a weaker Dev.

DO NOT: Do not classify the system into the bank CIS register from this slide.

Slide 13. Payment — customer device, not RM device (TB-6) (3 min)

SAY: Session-create goes out through Apigee. The customer completes 3-D Secure on their own device. The callback comes in on a separate API Gateway route, not on Priya's session. We do not mark SOLD because a payment API returned 200. We wait for RECONCILED. If the callback is lost, state is UNCERTAIN and we block a second attempt. Timeouts do not mint money.

IF ASKED: PAN never on the RM device and never in our logs. PG is the bank's existing payment gateway — we do not replace it.

DO NOT: Do not accept 'RM can pay on behalf for UAT demo' as an architecture exception.

Slide 14. DR — designed for later; not the ask today (3 min)

SAY: Warm standby in Hyderabad. RTO ≤ 1 hour, transactional RPO ≤ 5 minutes, audit RPO 0. Cache, MSK and OpenSearch are not replicated — by design. A DR region with no path to CBS cannot sell. We have not run the timed restore drill. That drill is a production/DR ARB evidence item (NFR-DR-04). Today we are not claiming DR-ready.

IF ASKED: Why not active-active? Bank SOP language for some tiers is active-active. We do not 'fix' that without an RIA tier and Aarti/Shivanshi. Warm standby matches RTO 1 hour. Play 4.

DO NOT: Do not say DR is proven. Do not skip Hyderabad in the design 'to save money' without Aarti.

Slide 15. Bank standard we consume vs what is different (4 min)

SAY: Read the red lines as the only things that might look 'new'. Public ALB is the neighbour pattern we refused. CUG we are not buying. Separate Dev account we are not asking for. Everything else is attach-don't-clone. If ARB can live with those three differences, Dev/UAT can be vended without an architecture rewrite.

IF ASKED: If they reject API Gateway inbound — that is a redesign, Deepali+Mahesh, not a hallway decision. Record it. Do not improvise a Public ALB 'for now'.

DO NOT: Do not present differences as rebellion. Present them as recorded ADRs with owners.

Slide 16. Tech stack (pins) — why these, not a catalogue (3 min)

SAY: We did not pick a fashion stack. We picked what the estate already runs and what keeps 1SB behind an adapter. A stack argument that does not change a control is a later conversation.

IF ASKED: FAQ on Lambda, Istio, Mongo, Kafka-as-audit. Play 1 with the cheat sheet.

DO NOT: Do not bash other teams' stacks. Do not agree to Istio 'because prod will need it'.

Slide 17. 19 ARB prerequisites — traffic light for THIS sitting (4 min)

SAY: Nothing on this list is a reason to refuse two VPCs in the UAT account. Several are reasons to refuse production. Please keep those in different columns. The pack, PDF, Excel and this deck are the evidence index. Humans still sign CIS, Board 4, T4, VA/PT.

IF ASKED: If they want every row green before Dev — that is production-ARB logic applied too early. Play 4.

DO NOT: Do not mark VA/PT or CIS as done.

Slide 18. What we need from ARB today (3 min)

SAY: To close: we are asking for a first-review observation on this architecture, and a non-objection to vendor Dev-inside-UAT and UAT VPCs attaching to the existing bank network.

We are not asking for production, DR-ready, CIS classification, or a VA/PT waiver.

Observations and improvements are welcome. Anything that needs numbers we do not have, we will take as a dated action. Thank you.

IF ASKED: If they will only write 'approved' — ask them to qualify: 'first review, Dev/UAT vending, production ARB still required'. Unqualified 'approved' is how we get blamed later.

DO NOT: Do not leave without a written observation, even if it is 'no objection to Dev/UAT subject to Deepali on firewall remainder'.

Slide 19. Parking lot — items that must not block Dev/UAT (2 min)

SAY: I will write every new question here with an owner. If it does not change CIDRs, attachments, or 'no public ALB', it does not block vending.

DO NOT: Do not let the parking lot become a redesign workshop.

Slide 20. Appendix — do not present unless asked (appendix)

SAY: We stop the main sitting here unless you want the glossary.

Slide 21. Appendix A — network words in one sentence each (appendix)

SAY: If a network SME quizzes you, stay on this table. You do not need to configure BGP in this meeting.

IF ASKED: If they go below this — Play 3, Shivanshi + bank network.

DO NOT: Do not draw BGP on a whiteboard unless Shivanshi is speaking.

Slide 22. Appendix B — five plays when you do not know (appendix)

SAY: These five sentences are how you stay professional without blocking Dev/UAT. Memorise Play 3 and Play 5.

DO NOT: Do not read this slide in the main hour unless you are using a play live.

Slide 23. Appendix C — questions we expect (answers in FAQ Excel) (appendix)

SAY: Flip here only if the room is circling. Full answers are in the FAQ workbook — 35 questions.

DO NOT: Do not invent a 36th answer on the whiteboard.

Close (memorise)

To close: we are asking for a first-review observation on this architecture, and a non-objection to vendor Dev-inside-UAT and UAT VPCs attaching to the existing bank network.

We are not asking for production, DR-ready, CIS classification, or a VA/PT waiver.

Observations and improvements are welcome. Anything that needs numbers we do not have, we will take as a dated action. Thank you.

FAQ

Q1. Why not a public / external ALB like other bank apps?

Neighbour apps enter AWS on a Public ALB. NIP's AWS entry is API Gateway, then an Internal ALB only (ADR-018). Cloudflare and F5-XC already are the bank perimeter. A public ALB in front of API Gateway adds a hop and a public target group we do not need. Copying the neighbour pattern is a change to ADR-018 and a Deepali exposure decision — not a Dev convenience.

Cite: ADR-018. Do not defer — answer from the ADR.

Q2. Why not put a public ALB in Dev only?

A public Dev is a production-shaped hole. Workload VPCs have no IGW in every environment. Internal ALB + API Gateway is the same shape in Dev, UAT and Prod. We will not invent a second ingress just to go faster.

Cite: ADR-018 / LLD §2. Do not defer — answer from the ADR.

Q3. Why API Gateway and Apigee — two API products?

They do different jobs. API Gateway is the inbound AWS front door for RM/mobile and PG callbacks. Apigee is the bank outbound loading dock for 1SB and internal bank APIs (ADR-020). Flutter never calls Apigee. Java never calls 1SB. One product doing both would hairpin internal APIs through the public edge or force 1SB to allowlist the wrong IPs.

Cite: ADR-020. Do not defer — answer from the ADR.

Q4. Why not Apigee on the front door instead of API Gateway?

Human Architecture owner split the plane on 2026-09-14. Inbound stays API Gateway. Drawing Apigee on ingress would put RM traffic on the outbound plane and fight the existing Cloudflare→F5 path. We will not redesign that in this sitting.

Cite: ADR-020. Do not defer — answer from the ADR.

Q5. Why no Internet Gateway on the workload VPC?

If a workload VPC has an IGW, someone will eventually attach a public IP to a pod or an ALB. Zero-trust language on the landing-zone slide means the only IGW is on the inspection/EDGE path. You cannot curl a pod from the internet. That is intentional.

Cite: LLD §2 / ADR-010. Do not defer — answer from the ADR.

Q6. What is a Transit Gateway and why do we need it?

Think of TGW as the bank's existing roundabout that already connects applications, EDGE firewalls and Direct Connect. We attach one spoke. We do not build an insurance-only roundabout. VPC peering meshes do not scale and would bypass hub inspection.

Cite: Estate 18 / BE-01 / ADR-009. Do not defer — answer from the ADR.

Q7. Why not a second TGW / second Direct Connect for insurance?

The bank already has AU-CTO-NETWORK TGW and DX Gateway. Cloning them is an A0 architecture defect (Board 1). Attach, do not clone (BE-01).

Cite: BE-01. Do not defer — answer from the ADR.

Q8. What is NAT? Why do we still have NAT if we use Apigee?

NAT lets private pods start outbound connections. It still sits on the inspection VPC for the hop toward Apigee and remaining internet. It is not what 1SB allowlists. 1SB allowlists Apigee's egress IPs. Publishing our NAT Elastic IPs to 1SB allowlists the wrong host (ADR-020).

Cite: ADR-010 remainder / ADR-020. Do not defer — answer from the ADR.

Q9. Please give us the IP list for 1SB now.

I will not invent IPs in this room. Action: Apigee team writes product + per-env IPs (DEP-20260914-apg). Dev uses stubs. That does not block vpc-dev.

Cite: DEP-20260914-apg. Defer OK. Shivanshi / API platform

Q10. Why Network Firewall instead of a FortiGate pair in our VPC?

FortiGate already exists in the hub EDGE VPC. Dropping another pair in the spoke would clone firewall operations the bank already staffs. Spoke NFW may inspect pod→Apigee; Deepali accepts that remainder. Hub FortiGate still inspects org paths.

Cite: ADR-010 / ASM-012. Defer OK. Deepali

Q11. Why F5 Distributed Cloud, not BIG-IP in AWS?

On this estate F5 is F5-XC SaaS, outside AWS. An in-VPC BIG-IP icon was a diagram mistake and was retracted in ADR-018.
Cite: ADR-018. Do not defer — answer from the ADR.

Q12. Why Cloudflare, not CloudFront?

Cloudflare Enterprise is the bank's north-south CDN/DDoS standard. CloudFront would be a second CDN the bank does not operate for this perimeter.
Cite: ADR-018. Do not defer — answer from the ADR.

Q13. Why Internal ALB, not NLB or a public Kubernetes LoadBalancer?

We need HTTP path routing: / to nip-web, /api to BFF. That is ALB. A Service type LoadBalancer with a public IP is exactly the exposure we refused.
Cite: LLD §3. Do not defer — answer from the ADR.

Q14. Why EKS, not ECS or Lambda everywhere?

EKS is listed IaaS on this estate and already used. Lambda-for-everything does not match long-running insurance journeys, private VPC-only data stores, or the service boundaries we need for a second LOB later. We are not anti-Lambda; we are anti-rewriting the platform as functions to look modern.
Cite: LLD BOM / AP-09. Do not defer — answer from the ADR.

Q15. Why Java 21 / Spring Boot, not Node or .NET?

LTS, already in the programme, Spring Boot 3.5 in support, CVE overrides pinned in Gradle. A language war does not change a trust boundary. We will not restart R0 on a new runtime.
Cite: Lifecycle paper. Do not defer — answer from the ADR.

Q16. Why not one InsuranceService monolith?

Every rule change would be a release, and Health later becomes a rewrite. Suitability and quote are different systems of record. Boundaries are the point of R0, not premature micro-max.
Cite: 03 SAD / R0-E2E §5. Do not defer — answer from the ADR.

Q17. Why Flutter?

One project, three artefacts: web, APK, IPA. Tokens never on the device. Three native apps would triple the control surface.
Cite: R0-E2E §2. Do not defer — answer from the ADR.

Q18. Why Keycloak if we have Active Directory?

AD is workforce only (TI-01). Partners must not enter AD. Keycloak (or equivalent) holds partner identities. Workforce verification is the existing AD-verify API, never LDAP from EKS. Fireframe/NIP-APP is the UI chrome.
Cite: ADR-020 / TI-01. Do not defer — answer from the ADR.

Q19. Why not LDAP from EKS to AD? It is simpler.

LDAP from a workload cluster to AD is a new credential path, a new secret, and a new blast radius. The bank already has an AD-verify API. We call it privately through Apigee.
Cite: ADR-020. Do not defer — answer from the ADR.

Q20. Why is Dev inside UAT? That is not isolation.

It is cost, with isolation by two VPCs, two route tables, namespaces, schemas and prefixes (ADR-020). Stubs cannot use the prod CBS route. A second AWS account is a Cloud exception we are not requesting.
Cite: SUG-20260914-uat / ASM-017. Do not defer — answer from the ADR.

Q21. Why no CUG?

No R0 consumer for CUG. Waiver, do not provision (ASM-018). We will not pay for an empty class of environment.
Cite: ASM-018. Do not defer — answer from the ADR.

Q22. Why warm standby, not active-active?

NFR RTO is 1 hour. Warm standby in ap-south-2 matches that. Active-active is a different money and data problem (RIA tier, Aarti, Shivanshi). We will not 'fix' SOP language in this hour without that evidence. DR proof is sitting 2.

Cite: NFR-DR / LLD §11. Defer OK. Aarti + Shivanshi

Q23. Is DR proven?

No. Designed, not drilled (NFR-DR-04). I will not claim a restore time we have not measured. That is exactly why this is not the production ARB.

Cite: NFR-DR-04. Do not defer — answer from the ADR.

Q24. Is this a Critical Information System?

Architecture proposes CIS because of CIF, KYC, health/suitability, payment orchestration and 7-year WORM audit. The bank CIS register is Shailja + CISO. We do not self-classify. Controls are already sized as if we were CIS — a lower class would be a written risk acceptance, not a cheaper Dev.

Cite: CIS proposal. Defer OK. Shailja + CISO

Q25. Where is the VA/PT report?

It does not exist. CI has Checkstyle, Spotless, ArchUnit, JaCoCo, lockfile SCA. DAST/VA/PT is before UAT exit / production ARB. We will not pentest an environment we have not been allowed to vendor.

Cite: Pack row 11. Do not defer — answer from the ADR.

Q26. Why isn't OpenSearch / Kafka the audit store?

Search retention is not a 7-year licence evidence. Kafka topic retention is not WORM. Audit is INSERT-only + S3 Object Lock (TI-07, ADR-013). Operational logs can be rebuilt. Evidence cannot.

Cite: ADR-013 / TI-07. Do not defer — answer from the ADR.

Q27. Why can't the RM pay on the iPad for the customer?

C4 — customer-device payment. That is regulatory, not UX. UAT demos use a customer-device step, not an RM card entry.

Cite: FF-14 / TB-6. Do not defer — answer from the ADR.

Q28. Why 1SB at all? Why not call insurers directly?

R0 uses 1SB as a provider route behind an adapter (TI-04). Direct insurer APIs are an R1+ sibling adapter. The Hub contract does not change. We are not locked to 1SB JSON in the domain.

Cite: TI-04 / ADR-020. Do not defer — answer from the ADR.

Q29. Are we compliant with the bank landing-zone / SOP?

We attach to Control Tower, TGW, DX, EDGE, GitLab, Terraform, IAM IC, India SCPs. Differences are recorded: API Gateway inbound not Public ALB; no CUG; Dev-inside-UAT; no workload IGW. Those are ADRs, not silent deviations. Human T4 still outstanding.

Cite: Estate 18 / ADR-018/020. Defer OK. Mahesh T4 + Shivanshi

Q30. Can we put Flutter on public S3?

No. SOP: no public buckets. Authenticated app is not a brochure site. Static assets come through nip-web on the same ingress chain.

Cite: LLD BOM / SOP. Do not defer — answer from the ADR.

Q31. Why not Istio / service mesh in R0?

Not in R0. We already have NetworkPolicy, PDP, and two reverse proxies. A mesh is a new control plane with no named R0 problem (AP-09).

Cite: Lifecycle 'not in R0'. Do not defer — answer from the ADR.

Q32. Can we start Dev without Direct Connect?

Yes. Dev uses stubs for CBS/AD-verify. UAT needs VPN first, then existing DX as primary (ADR-009). Do not block vpc-dev on a carrier order.

Cite: ADR-009 / DEP-20260824-dx1. Do not defer — answer from the ADR.

Q33. Who signs T4 Architecture?

A human Mahesh, not this deck. We draft; we do not sign. Same for Deepali Board 4 and Shailja CIS.

Cite: Authority card. Do not defer — answer from the ADR.

Q34. Why Hyderabad, not another region?

India residency (TI-08) plus bank DR region already in use (ap-south-2). Data does not leave India.

Cite: TI-08 / FF-08. Do not defer — answer from the ADR.

Q35. What if ARB wants a full production pack today?

We cannot evidence timed DR, VA/PT, or CIS registration today. Forcing those now either invents evidence or delays Dev/UAT indefinitely. We ask for a staged review. Production ARB will be scheduled with that evidence.

Cite: This sitting's ask. Do not defer — answer from the ADR.